MASTG

MASTG-TEST-0201: Runtime Use of APIs to Access External Storage

MASTG-TEST-0202: References to APIs and Permissions for Accessing External Storage

MASTG-TEST-0203: Runtime Use of Logging APIs

MASTG-TEST-0207: Runtime Storage of Unencrypted Data in the App Sandbox

MASTG-TEST-0216: Sensitive Data Not Excluded From Backup

MASTG-TEST-0231: References to Logging APIs

MASTG-TEST-0262: References to Backup

L2 ANDROID MASWE-0006 TEST

MASTG-TEST-0207: Runtime Storage of Unencrypted Data in the App Sandbox

Overview

The goal of this test is to retrieve the files written to the internal storage (*Internal Storage*) and inspect them regardless of the APIs used to write them. It uses a simple approach based on file retrieval from the device storage (*Host-Device Data Transfer*) before and after the app is exercised to identify the files created during the app's execution and to check if they contain sensitive data.

Steps

1. Start the device.
2. Take a first copy of the app's private data directory (*Accessing App Data Directories*) to have as a reference for offline analysis. You can use *adb* for example.
3. Launch and use the app going through the various workflows while inputting sensitive data wherever you can. Taking note of the data you input can help identify it later using tools to search for it.
4. Take a second copy of the app's private data directory for offline analysis and make a diff using the first copy to identify all files created or modify during your testing session.

Observation

The output should contain a list of files that were created in the app's private storage during execution.

Evaluation

Attempt to identify and decode data that has been encoded using methods such as base64 encoding, hexadecimal representation, URL encoding, escape sequences, wide characters and common data obfuscation methods such as xoring. Also consider identifying and decompressing compressed files such as tar or zip. These methods obscure but do not protect sensitive data.

Search the extracted data for items such as keys, passwords and any sensitive data inputted into the app. The test case fails if you find any of this sensitive data.

Demos

MASTG-DEMO-0010: File System Snapshots from Internal Storage

MASTG-DEMO-0059: Using SharedPreferences to Write Sensitive Data Unencrypted to the App Sandbox